

SVILUPPO DI UN COVERT CHANNEL ICMP PER L'ESFILTRAZIONE DEI DATI

F. Santini, M. Mecarelli

Perugia – February 6, 2026

Available at <https://github.com/mcrrmc/Tesi-Magistrale---M.-Mecarelli-F.-Santini.git>

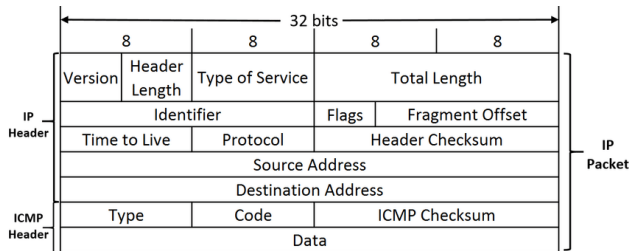
INTRODUZIONE

La sicurezza delle comunicazioni e delle reti informatiche rappresenta oggi una delle sfide più critiche data la continua evoluzione delle tecnologie e il costante aumento nella complessità dei sistemi. Questi fattori portano alla scoperta di nuove vulnerabilità e vettori di attacco. In particolare ci focalizzeremo sui Covert Channel, una minaccia particolarmente insidiosa, in quanto permette la trasmissione di informazioni fra due entità ma la cui individuazione risulta complessa.

Nella seguente presentazione, verranno indicate le fasi di analisi e sviluppo di un Covert Channel basato sul protocollo ICMP.

INTERNET CONTROL MESSAGE PROTOCOL

ICMP è un protocollo che opera al livello di rete (livello 3 modello ISO/OSI), e permette la segnalazione di errori, la diagnostica della rete e la messaggistica di controllo. Queste caratteristiche lo rendono fondamentale nelle reti e proprio per questo, non può essere completamente disabilitato o filtrato senza compromettere l'operatività della rete stessa. Ciò lo rende un candidato ideale per la creazione di canali di comunicazione nascosti.



Struttura di un messaggio ICMP

Utilizzi	Descrizione
Diagnostica della rete	Fornisce metriche critiche per il monitoraggio continuo delle prestazioni della rete
Segnalazione di errori	Rileva e segnala i problemi riscontrati durante la trasmissione dei dati tra i dispositivi sulla rete
Risoluzione dei problemi	Gli amministratori di rete possono ricevere avvisi in tempo reale e rispondere rapidamente ai problemi di rete grazie agli strumenti di monitoraggio basati su ICMP.
Ottenimento di informazioni	Invia messaggi e informazioni senza la necessità di una connessione preventiva.

Utilizzi del protocollo ICMP

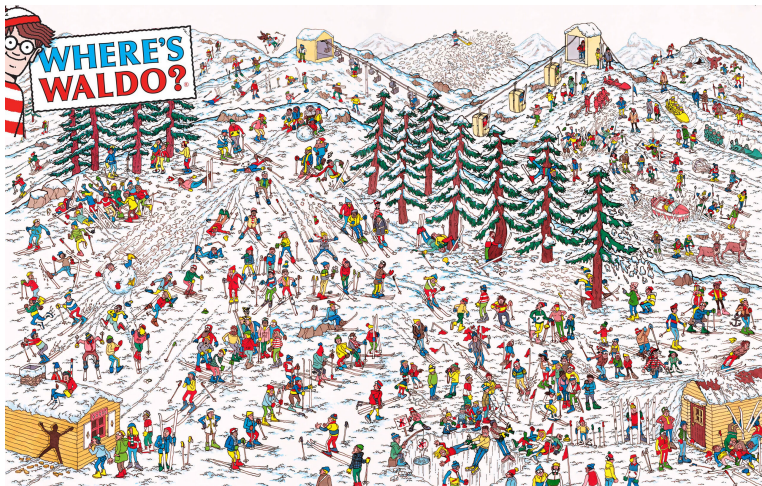
COVERT CHANNEL

È un attacco che permette (in ambienti ritenuti sicuri) la capacità di comunicare o trasferire dati in maniera non autorizzata e non voluta. Solitamente sfruttano vulnerabilità o comportamenti non previsti nei sistemi per operare al di fuori dei soliti meccanismi di comunicazione.

Caratteristica	Descrizione
Furtività	Evitare di attirare le attenzioni sia degli amministratori che degli strumenti di sicurezza.
Capacità di trasmissione	La quantità di dati che il canale riesce a trasmettere. Una quantità elevata può portare ad una rilevazione del canale.
Uso delle risorse	Un uso delle risorse improprio (o sproporzionato) potrebbe andare in conflitto con le risorse legittime presenti nel sistema.
Rumore	L'uso dei servizi e/o delle risorse nel sistema potrebbe alterare il loro funzionamento.
Indistinguibilità	La trasmissione dei dati mantiene inalterato il funzionamento delle risorse utilizzate. Ovvero il canale è indistinguibile dalla risorsa usata.

Caratteristiche di un Covert Channel

CARATTERISTICHE DI UN COVERT CHANNEL



TIMING COVERT CHANNEL

I **Timing Covert Channel** sono metodi di comunicazione che permettono ad un osservatore (e.g una persona od un processo) di acquisire informazioni attraverso il cambiamento del tempo di risposta di una risorsa.

Qualsiasi metodo che utilizzi un orologio (o che misuri il tempo) può implementare questa tipologia di canale.

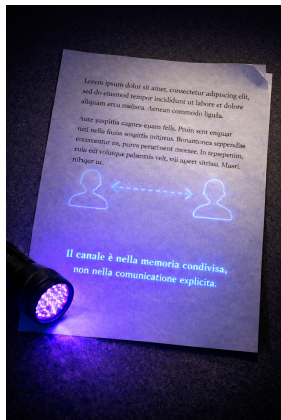


A	--	J	----	S	...	2	-----
B	----	K	---	T	-	3	-----
C	----	L	---	U	...	4	-----
D	--	M	--	V	----	5	
E	.	N	--	W	---	6	-----
F	----	O	---	X	----	7	-----
G	---	P	----	Y	----	8	-----
H	----	Q	----	Z	----	9	-----
I	--	R	---	1	-----	0	-----

STORAGE COVERT CHANNEL

Uno **Storage Covert Channel** scrive dei dati su un'area di memoria condivisa accessibile da tutte le entità coinvolte nella comunicazione.

I veicoli per la sua implementazione saranno tutte quelle risorse che consentiranno la scrittura e la lettura sulla risorsa condivisa.



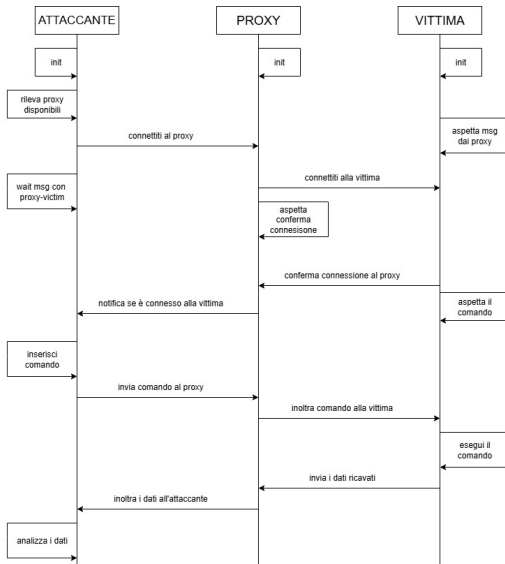
BEHAVIOURAL COVERT CHANNEL

Nei **Behavioural Covert Channel** le informazioni vengono codificate mediante la variazione del comportamento del sistema.

I dati verranno quindi ricavati tramite l'osservazione del sistema piuttosto che attraverso l'accesso (diretto o indiretto) alla memoria.



STRUTTURA DELA COMUNICAZIONE



Flusso di comunicazione fra le entita

STRUTTURA DELL'ATTACCANTE

Opzione	Utilizzo
Path file	Percorso per il file di configurazione da caricare. In questo file JSON viene specificato l'indirizzo IP della vittima, la metodologia di attacco e la lista dei proxy che si vogliono usare.

Tramite il file di configurazione specificato, l'attaccante definisce l'**indirizzo IP della vittima**, il **metodo di attacco** per l'esfiltrazione dei dati ed i **proxy che si vogliono utilizzare** verificando successivamente quali (fra quelli specificati) sono utilizzabili.

Dopodichè inserirà il comando che si vorrà far eseguire dalla vittima (o i dati che gli si vuole mandare). Una volta ricevuti tutti i pacchetti, li riordinerà per ricavare correttamente il dato esfiltrato ed infine potrà decidere se inviare un ulteriore comando o se terminare la comunicazione.

STRUTTURA DEL PROXY

Opzione	Utilizzo
Indirizzo IP	Rappresenta l'indirizzo IP dell'attaccante.

Durante la fase di inizializzazione il proxy necessita di sapere l'indirizzo IP dell'attaccante così da stabilire una connessione solamente con lui; tutti i tentativi di connessione provenienti da indirizzi diversi verranno scartati.

Una volta stabilita la connessione, il proxy aspetterà che l'attaccante gli invii l'indirizzo IP della vittima ed il metodo di attacco scelto. Ricevuto l'indirizzo il proxy si assicurerà che la comunicazione con esso sia possibile. Nel caso non sia possibile, il proxy aggiornerà l'attaccante che non potrà essere utilizzato per l'esfiltrazione dei dati dalla vittima. Entrambe le entità procederanno poi alla chiusura della comunicazione.

I successivi messaggi da parte dell'attaccante potranno essere:

- Il messaggio indicante il comando da inoltrare alla vittima.
- Il messaggio indicante che il proxy non ha ricevuto il comando e che dovrà procedere ad ascoltare i dati provenienti dalla vittima.
- Il messaggio indicante la terminazione della comunicazione.

Inoltrato il comando aspetta poi che la vittima inizi ad inviare i dati che dovranno essere poi inoltrati all'attaccante.

Un volta terminato, rimarrà in ascolto di aggiornamenti da parte dell'attaccante, che potranno essere o un nuovo comando oppure la notifica sulla chiusura della comunicazione. Nel secondo caso provvederà ad aggiornare la vittima della cosa.

STRUTTURA VITTIMA

Opzione	Utilizzo
Numero connesisoni	Numero minimo di connesisoni necessarie per l'esecuzione dell'attacco.

Nella fase di inizializzazione alla vittima verranno indicate la quantità di connessioni attive necessarie per l'esecuzione dell'attacco. Queste connessioni verranno poi usate sia per la ricezione del comando che per l'esfiltrazione dei dati.

In questa fase, il proxy (o l'attaccante) che si vuole connettere indicherà alla vittima anche l'attacco che si userà per lo scambio dei dati.

Definiti i porxy disponibili, la vittima aspetterà di ricevere un comando. Alla sua ricezione, lo eseguirà ed i dati ricavati verranno inviati all'attaccante tramite le connessioni precedentemente stabilite.

ULTERIORI ASPETTI RELATIVI ALL'IMPLEMENTAZIONE

Si ritiene fondamentale la presenza di più **proxy intermediari** fra l'attaccante e la vittima. Ciò permette di distribuire in modo omogeneo il carico sulla rete che verrà generato dall'esfiltrazione dei dati.

Un limite alla **quantità di dati** inviabili in un intervallo di tempo ed un periodo di riposo prima di poterne inviare degli altri. Questo per permettere l'invio di file di grosse dimensioni evitando di congestionare il canale di comunicazione.

L'invio di un **messaggi di tipo Request** richiede la ricezione di una risposta; che normalmente sarà uguale al messaggio inviato. Una soluzione può essere l'invio di soli messaggi di tipo Reply oppure la disabilitazione delle risposte così da poterne inviare una noi stessi.

IMPLEMENTAZIONE TIMING COVERT CHANNEL

Per poter temporizzare i dati da inviare, c'è bisogno di definire un metodo che permetta la codifica e decodifica degli intervalli temporali.

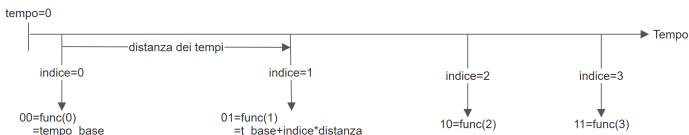
Nelle prossime slides si mostrerà come è stata definita la funzione che sarà responsabile di mappare un dato binario ad un intervallo di tempo.

Nella **codifica** si calcolerà il delay temporale che verrà associato al dato da inviare tramite una funzione che si occuperà di associare ad un dato un possibile tempo di delay.

Per la **decodifica**, il destinatario osserva il flusso dei pacchetti per poter calcolare la differenza di tempo fra il pacchetto precedente e quello attuale. Il dato verrà quindi ricavato controllando a quale informazione è stato mappato l'intervallo ricevuto.

IMPLEMENTAZIONE DELLA FUNZIONE

In una prima implementazione si ricava il tempo di delay associando ad ogni valore una distanza temporale in base alla distanza che due dati devono avere fra di loro.



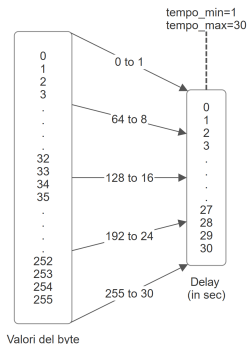
$$\text{tempo_base} + \text{indice} * \text{distanza_tempi}$$

Lo svantaggio dell'approccio sarà relativo ai tempi che si aspetteranno. Per risolvere il problema, si è pensato di ridurre i valori inviabili solo ai caratteri stampabili, che nella codifica ASCII vanno da 32 a 126.

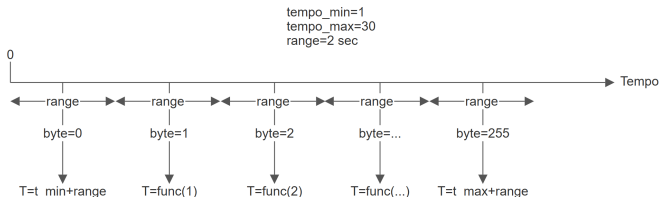
Sviluppando meglio l'idea e prendendo spunto da ICMP Exfill, il tempo di delay ora viene visto come il valore intero del byte che si vuole inviare. Dopodichè si normalizzerà l'intervallo dei valori ottenibili fra un valore minimo ed uno massimo.

$$\text{min_delay} + (\text{byte}/255) * (\text{max_delay} - \text{min_delay})$$

Tramite questo approccio, il range dei delay viene ristretto in un intervallo definito. Inoltre permetterà di regolare la velocità di trasmissione delle informazioni ma sacrificando la sensibilità della comunicazione ai ritardi di che possono avvenire durante il transito dei pacchetti.



Una funzione in cui lo schema dei tempi di invio dei pacchetti sembri casuale, permetterà di essere rilevati con maggiore difficoltà. Si aggiungerà quindi al Timing Covert Channel del rumore così che i tempi di delay sembrino casuali.



Ciò porta alla necessità che, per potersi scambiare i dati, il mittente e il destinatario devono sincronizzarsi sulla quantità di rumore aggiunto. Inoltre al destinatario dovrà essere indicato l'inizio della trasmissione o tramite un particolare valore o una particolare tipologia di messaggio.

IMPLEMENTAZIONE STORAGE COVERT CHANNEL

In questo Storage Covert Channel la risorsa condivisa sarà il pacchetto ICMP inviato. Il mittente memorizzerà i dati da esfiltrare nei campi presenti nel messaggio mentre il destinatario, una volta ricevuto, leggerà i valori codificati all'interno dei pacchetti.

Tipologia	Byte per pacchetto	Campi Sfruttati
Packet Too Big	40+8+41 →min 89 byte	mtu invoking packet
Destination Unreachable Time Exceeded	40+8+41 →min 89 byte	unused invoking packet
Parameter Problem	40+8+41 →min 89 byte	pointer invoking packet
Echo Request/Reply	40+8+32 →min 80 byte	identifier data

Tipologie di messaggi ICMPv6 usati

Tipologia	Byte per pacchetto	Campi Utilizzati
Redirect Message	20+8+21 →min 49 byte	header+64 bits
Destination Unreachable Time Exceeded Source Quench	20+8+21 →min 49 byte	unused header+64 bits
Parameter Problem	20+8+21 →min 49 byte	pointer unused header+64 bits
Information Request/Reply	20+8 →28 byte	identifier
Echo Request/Reply	20+8+32 →min 60 byte	identifier data
Timestamp Request/Reply	20+8+12+32 →min 72 byte	identifier timestamp data

Tipologie di messaggi ICMPv4 usati

INSERIMENTO DEI DATI NEL CAMPO HEADER+64 BITS

Nel campo sono presenti l'header IP più 8 byte per una lunghezza complessiva di 28 byte.

Nel nostro caso si inserirà un pacchetto ICMP/IP e siccome non rappresenta un datagram da inviare ma già spedito, si possono sfruttare un maggior numero di campi.

In questo campo si potranno quindi inserire **9 byte** di dati.

IP in ICMP

version	4b	4
ihl	4b	5
tos	1B	0x0
len	2B	16975
id	2B	21063
flags	0B	
frag	13b	0
ttl	1B	79
proto	1B	icmp
chksum	2B	0x5a5
src	4B	192.168.1.10
dst	4B	8.8.8.8
options	0B	[]

ICMP in ICMP

type	1B	echo-reply
code	1B	0
chksum	2B	0x776f
id	2B	0x474e
seq	2B	0x4142
unused	0B	b"

Messaggio ICMP con campo
Header+64 bit impostato

Header IPv4

Campo	Byte	Utilizzo
Time to live	1 byte	Tempo di vita del pacchetto
Total length	2 byte	Dimensione dell'intero pacchetto
Identification	2 byte	Identifica i frammenti di un pacchetto IP

Header ICMPv4

Campo	Byte	Utilizzo
Identifier	2 byte	Identificativo del messaggio di richiesta invocato
Sequence	2 byte	Numero di sequenza del messaggio di richiesta invocato

Uso del Header+64 bits nel caso di IP/ICMP

INSERIMENTO DEI DATI NEL CAMPO UNUSED

Dalle specifiche RFC (792 e 4434) il campo deve essere vuoto. Quindi utilizzando i metodi presenti nel framework Scapy per la creazione del pacchetto, qualsiasi valore inserito al suo interno verrà azzerato.

Il problema viene risolto tramite l'uso della libreria **struct**. Con essa è possibile costruire un pacchetto avente i dati all'interno del campo e successivamente si userà Scapy solo per l'invio.

IP

version
ihl
tos
len
id
flags
frag
ttl
proto
chksum
src
dst
options

ICMP

type
code
chksum
ptr
length
unused
extpad
ext

4b 4
4b 5
1B 0x0
2B 56
2B 1
0B
13b 0
1B 64
1B icmp
2B 0xf715
4B 192.168.1.15
4B 192.168.1.79
0B []
1B parameter-problem
1B ip-header-bad
2B 0x5f69
1B 66
1B 79
2B 21063
0B b"
0B None

Messaggio ICMP con campo *unused* impostato

INSERIMENTO DEI DATI NEL CAMPO DATA

Nel campo il mittente può inserire quanti dati preferisce. Ma per sicurezza la dimensione sarà o 32 o 64 byte. Inoltre una quantità di dati eccessiva può far mandare più pacchetti di risposta nel caso si fosse inviata una richiesta.

ICMP

type
code
chksum
id
seq
unused

1B echo-reply
1B 0
2B 0x6f05
2B 0x1
2B 0x0
0B b''

Raw

load

64B b'BORGOGNABORGOGNA[...]

Messaggio ICMP con campo *Data*
impostato

INSERIMENTO DEI DATI NEL CAMPO TIMESTAMP

In ciascun campo timestamp verrà inserito un byte nella parte dei milisecondi. Non è possibile inserire ulteriori informazioni nelle altre parti del campo siccome rappresentano le ore, i minuti ed i secondi. Un'alternativa è l'inserire il dato in tutto il campo ma, rappresentando un valore temporale, ciò porterebbe al rischio di avere tempi errati o non congruenti. Per esempio il pacchetto risulta ricevuto prima che sia stato inviato.

ICMP

type
code
chksum
id
seq
ts_ori
ts_rx
ts_tx
unused

1B timestamp-reply
1B 0
2B 0xb3
2B 0x424f
2B 0x0
4B 22:42:16.82
4B 22:42:17.71
4B 22:42:18.79
0B b"

Messaggio ICMP Timestamp
Request/Reply

Dato nascosto: b'r' 114
Dato nascosto: b'g' 103
Dato nascosto: b'o' 111

Timestamp origin prima:
2025-11-07 23:13:36.146254+00:00

Timestamp origin dopo:
2025-11-07 23:13:36.114000+00:00

Tempo nel campo:
83616114

Esempio di un dato inserito nel
campo Timestamp

ICMP

type	1B timestamp-reply
code	1B 0
chksum	2B 0xb3
id	2B 0x424f
seq	2B 0x0
ts_ori	4B 22:42:16.82
ts_rx	4B 22:42:17.71
ts_tx	4B 22:42:18.79
unused	0B b"

Messaggio ICMP con i campi
Timestamp impostati

INSERIMENTO DEI DATI NEL CAMPO POINTER E MTU

Il campo **Pointer** indica l'ottetto del messaggio in cui è presente l'errore; tuttavia può contenere dei dati non correlati ad esso. Nel nostro caso, verranno inseriti tanti dati quanto la sua capacità.

Nel campo **MTU** invece viene indicata la capacità massima del collegamento. L'intera dimensione del campo verrà usata per l'inserimento dei dati. Anche in esso si inseriranno tanti dati quanto la sua capacità.

ICMP

type
code
chksum
ptr
length
unused
extpad
ext

1B parameter-problem
1B ip-header-bad
2B 0xb1ff
1B 66
1B 0
2B 0
0B b"
0B None

Messaggio ICMP con campo *pointer* impostato

INSERIMENTO DEI DATI NEL CAMPO INVOKING PACKET

Invece nel campo **Invoking Packet** verrà indicato il pacchetto che ha causato l'errore. Nel nostro caso si userà un pacchetto IP/ICMP. Tramite i campi sfruttati si riesce ad inserire **7 byte** di dati.

Header IPv6

Campo	Byte	Utilizzo
Payload Length	2 byte	Tempo di vita del pacchetto
Hop Limit	1 byte	Decrementato di 1 per ogni nodo che inoltra il pacchetto

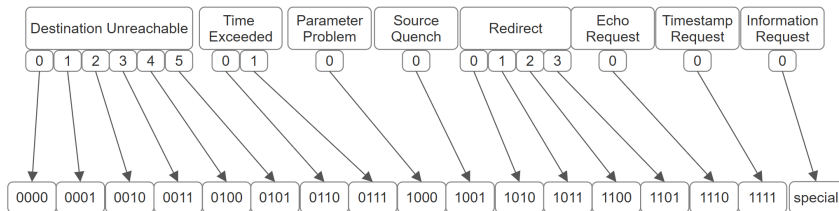
Header ICMPv6

Campo	Byte	Utilizzo
Identifier	2 byte	Identificativo del messaggio di richiesta invocato
Sequence	2 byte	Numero di sequenza del messaggio di richiesta invocato

Struttura del campo Invoking Packet

IMPLEMENTAZIONE BEHAVIOURAL COVERT CHANNEL

Nel Behavioural Covert Channel implementato, l'evento sarà definito dall'arrivo di un messaggio ICMP. Il destinatario ricaverà il dato trasmesso osservando la tipologia di messaggio ed il codice presente per poi vedere a quale informazione è mappata la coppia.



Siccome il numero di eventi possibili sono 17, ognuno permetterà di codificare 4 bit alla volta ($\log_2 16 = 4$). L'evento rimasto inutilizzato, verrà usato per indicare l'inizio e la terminazione dell'invio dei dati.

```
data='m'  
data.hex=0x6D  
data.bytes=b'0110 1101'
```

#PRIMO EVENTO

Maschera il byte con b'11110000' per ottenere: 0x60
Effettua lo shift a destra per ottenere: 0x06 (0110)
Si ottiene come tipologia: Time Exceeded (tipo 11)
Si ottiene come codice: 0 (Time to Live exceeded in Transit)
Invia un messaggio ICMP Time Exceeded con codice 0

#SECONDO EVENTO

Maschera il byte con b'00001111' per ottenere: 0x0D (1101)
Si ottiene come tipologia: Redirect (tipo 5)
Si ottiene come codice: 3 (Redirect for the host)
Invia un messaggio ICMP Redirect con codice 3

Esempio dell'invio di un byte

TIPOLOGIE DI MESSAGGI DEPRECATI

Un problema di questa implementazione, sono le tipologie deprecate dei messaggi. Questi messaggi potranno comunque essere inviati ma le linee guida indicano ai router di ignorarli e all'host utente di non mandarli.

L'uso di tipologie deprecate renderà il canale meno legittimo e maggiormente individuabile siccome il traffico sarà visto con sospetto. Infine date le linee guida, non è assicurata la ricezione dei messaggi.

Tipologia Messaggio	Motivo
Information Request/Reply	è stato sostituito da protocolli come il DHCP.
Source Quench	data la sua inefficienza, è stato sostituito dai meccanismi presenti nel protocollo TCP.

Tipologie di messaggi deprecati

TEST E RISULTATI

Inizialmente si sono effettuati test in cui si inviava il dato una singola volta. Dai risultati ottenuti si ottiene che RITA non ha mostrato la presenza dei Covert Channel.

Uno step successivo per l'esecuzione dei test è l'invio degli stessi dati più volte (in particolare tre volte). Inoltre al test si aggiungeranno dei parametri così da poter verificare meglio cosa avviene. L'obiettivo è determinare come RITA risponde alle comunicazioni con queste caratteristiche.

Parametro	Possibili valori
Quantità di dati inviati	1KB, 10KB, 100KB, 1MB
L'utilizzo dei campi usati nei messaggi ICMP	unused, data
Delay fra i blocchi di dati	Nessuno, 15 secondi
Attesa prima di un nuovo invio	1 ora, 30 minuti, 15 minuti
Il mittente del messaggio	IP dell'host, IP assegnati nella rete, IP non assegnati nella rete

Parametri usati nei test

Principalmente i test avverranno esfiltrando i dati tramite messaggi ICMP Echo nei quali verrà sfruttato il campo payload per l'inserimento delle informazioni.

Dai risultati ottenuti si nota che l'uso di ulteriori mittenti (oltre a quello assegnato all'host), permette di ridurre la gravità assegnata alla connessione e in alcuni casi anche il Beacon score.

Dai testi risulta anche che un tempo di attesa (abbastanza lungo) fra un'esfiltrazione e la successiva diminuisce la gravità assegnata alla comunicazione (oltre al suo Beacon Score).

Dall'analisi dei test risulta anche che un invio sequenziale dei dati sembra un metodo efficace per non essere rilevati. Tuttavia l'efficacia sarà determinata anche in base alla dimensione di dati che si vuole esfiltrare.

CONCLUSIONI FINALI

In queste diapositive si è quindi presentato lo sviluppo e l'implementazione di un canale nascosto tramite il protocollo ICMP. L'obiettivo era dimostrare come il protocollo, fondamentale per il funzionamento delle reti, potesse essere sfruttabile per la creazione di un Covert Channel che possa esfiltrare delle informazioni.

Si è descritto l'implementazione della comunicazione fra le entità presenti nel sistema e successivamente l'implementazione delle seguenti tipologie di Cover Channel:

- Storage Covert Channel: inserendo i dati nei campi dei messaggi ICMP.
- Timing Covert Channel: codificando le informazioni tramite una funzione al cui valore finale verrà aggiunto del rumore casuale.
- Behavioural Covert Channel: codifica i dati attraverso degli eventi definiti dalla coppia Tipologia e Codice del messaggio ICMP.

Dopodiché si sono testati i Covert Channel tramite RITA e dalle analisi risulta che la rilevabilità di un Covert channel dipende dai seguenti fattori:

- La frequenza con cui si inviano i dati.
- La quantità di pacchetti mandati da una sorgente in uno o più intervalli di tempo.

Sebbene sia un protocollo funzionale al monitoraggio di rete, i messaggi ICMP devono essere limitati solo a quelle tipologie essenziali alla rete E fra queste bisogna monitorare il loro utilizzo ed il loro contenuto. Ciò richiederà un ispezione dei pacchetti presenti nel flusso, un analisi statistica per la ricerca di pattern e la limitazione nella rete dei messaggi ICMP.